

Information Security Policy

Enterprise Security Framework and Controls

CONFIDENTIAL

Document ID

MIG-POL-002

Effective Date

February 1, 2026

Approved By

Board Risk Committee

Review Cycle

Semi-Annual

Version

5.1

Document Owner

A. Nakamura, CISO

Regulatory Alignment

PCI DSS 4.0, NAIC MDL-668, SOX, NIST CSF 2.0

Document Control

Revision History

Version	Date	Author	Changes	Approved By
5.1	Feb 2026	A. Nakamura	Updated SSL inspection mandate to zero exceptions	Board Risk Committee
5.0	Aug 2025	A. Nakamura	PCI DSS 4.0 alignment, MFA for all users	Board Risk Committee
4.8	Feb 2025	D. Lopez	Added IoT blocking requirement	A. Nakamura
4.5	Aug 2024	D. Lopez	Enhanced data classification tiers	A. Nakamura
4.0	Jan 2024	M. Singh	Major revision - NAIC MDL-668 compliance	Board Risk Committee

Approval Signatures

Role	Name	Signature	Date
Document Owner	A. Nakamura, CISO	_____	February 1, 2026
CISO	Board Risk Committee	_____	February 1, 2026
General Counsel	Legal Department	_____	February 1, 2026

Distribution

This document is distributed to all employees via the corporate policy portal, Information Security, IT Operations, Compliance and Risk Management, Legal, Internal Audit, and the Executive Leadership Team.

Related Documents

Document ID	Title	Relationship
MIG-POL-001	Acceptable Use Policy	Sibling
MIG-POL-002	Information Security Policy	Sibling
MIG-POL-003	Data Sharing and Transfer Policy	Sibling
MIG-POL-004	Network Security Standard	Technical Standard
MIG-POL-005	Vendor Access Policy	Sibling
MIG-STD-010	Encryption Standards	Technical Standard
MIG-STD-012	IAM Standard	Technical Standard

Table of Contents

1. Purpose, Scope, and Regulatory Framework

2. Encryption and Traffic Inspection Standards

2.1 Data in Transit

2.2 SSL/TLS Inspection Mandate

2.3 SSL Inspection Exception Process

3. Data Classification and Encryption at Rest

4. Access Control and Authentication

4.1 Multi-Factor Authentication

4.2 Password Management

4.3 Privileged Access Management

5. Network Security Controls

5.1 IoT and Non-Standard Device Security

5.2 Environment Segmentation

5.3 Malware and Ransomware Protection

5.4 DNS Security

5.5 API and Application Security

6. Security Monitoring and Incident Response

7. Compliance Auditing

1. Purpose, Scope, and Regulatory Framework

This Information Security Policy establishes the comprehensive security framework for all Meridian Insurance Group information systems, networks, data processing activities, and third-party integrations. It applies to all technology environments including on-premises data centers, cloud infrastructure (AWS, Azure), SaaS applications, branch office networks, and remote access pathways. Every employee, contractor, vendor, and system that processes, stores, or transmits Meridian Insurance Group data must comply with this policy.

This policy is aligned with and supports compliance with the following regulatory and industry frameworks:

- **PCI DSS 4.0** - Payment Card Industry Data Security Standard (effective March 2025)
- **NAIC Insurance Data Security Model Law (MDL-668)** - adopted in 23 states
- **SOX Section 404** - Internal controls over financial reporting
- **NIST Cybersecurity Framework 2.0** - voluntary risk management framework
- **State privacy laws** - CCPA/CPRA, NYSHIELD Act, and applicable state regulations

The Chief Information Security Officer (CISO) is the executive owner of this policy. The Information Security Governance team is responsible for maintaining, updating, and communicating changes. This policy is reviewed semi-annually by the Board Risk Committee.

2. Encryption and Traffic Inspection Standards

2.1 Data in Transit

All data transmitted across Meridian Insurance Group networks, including internal east-west traffic and internet-bound north-south traffic, must be encrypted using TLS 1.2 or higher. TLS 1.0 and TLS 1.1 are prohibited and must be disabled on all servers, load balancers, and API endpoints. SSL 3.0 is prohibited.

2.2 SSL/TLS Inspection Mandate

To detect threats hidden in encrypted traffic, enforce DLP policies on encrypted channels, and satisfy regulatory inspection requirements, Meridian Insurance Group mandates comprehensive SSL/TLS inspection on all web traffic:

CRITICAL REQUIREMENT: MIG-POL-002-SSL01

All web traffic, including HTTPS, must be subject to SSL/TLS decryption and inspection without exception. This requirement is mandated by PCI DSS Requirement 4.1 and applies to **all URL categories** including, but not limited to: financial services, healthcare, cloud storage, social networking, streaming media, government, education, and general business websites. **No URL category, domain, or IP address shall be exempted from SSL inspection** without (a) written approval from the CISO, (b) documented risk acceptance, and (c) entry in the SSL Inspection Exception Register with a 90-day expiration. As of the last quarterly review (Q1 2026), zero exceptions have been granted.

2.3 SSL Inspection Exception Process

Requests for SSL inspection exceptions must follow the formal exception process:

- Submit Exception Request Form (ISG-EXC-001) with business justification

- Risk assessment by Information Security team (5 business day SLA)
- CISO written approval required for all exceptions
- Maximum exception duration: 90 days (renewable with re-justification)
- All exceptions logged in the SSL Inspection Exception Register
- Quarterly review by CISO - expired exceptions automatically revoked

3. Data Classification and Encryption at Rest

Meridian Insurance Group classifies all data into four tiers based on sensitivity and regulatory requirements. Each tier prescribes minimum encryption standards for data at rest:

POLICY MANDATE: MIG-POL-002-ENC01

All data classified as Tier 1 (Restricted) or Tier 2 (Confidential) must be encrypted at rest using **AES-256 encryption or equivalent**. Platform-provided encryption (such as Microsoft BitLocker default configuration or cloud provider default encryption) **does not satisfy this requirement** unless independently verified to meet the AES-256 standard. OneDrive for Business default encryption (AES-128 BitLocker) does not meet this standard for Tier 1 or Tier 2 data.

Tier	Classification	Encryption at Rest	Access Control	Examples
1	Restricted	AES-256 mandatory	Named individuals only	PII, PHI, PCI cardholder data, trade secrets
2	Confidential	AES-256 mandatory	Role-based, need-to-know	Financial reports, M&A materials, strategy docs
3	Internal	AES-128 minimum	All employees	Internal memos, project plans, org charts
4	Public	None required	Unrestricted	Press releases, marketing materials, job postings

4. Access Control and Authentication

4.1 Multi-Factor Authentication

Multi-factor authentication is a foundational security control at Meridian Insurance Group. The following mandate applies to all user authentication scenarios:

CRITICAL REQUIREMENT: MIG-POL-002-MFA01

Multi-factor authentication (MFA) is required for ALL users accessing any corporate system, regardless of role, privilege level, or access method. MFA is **not limited to administrative accounts**. Standard employees, contractors, temporary workers, and third-party vendor users must all authenticate using a minimum of two distinct factors (knowledge + possession or knowledge + biometric). This applies to: VPN access, cloud application access, email access from non-corporate networks, remote desktop sessions, and all zero trust network access (ZTNA) connections.

4.2 Password Management

All user accounts must enforce password rotation every 90 days. Passwords must meet the following minimum complexity: 14 characters minimum length, at least one uppercase, one lowercase, one numeral, one special character. Previous 12 passwords may not be reused. Account lockout after 5 consecutive failed attempts.

4.3 Privileged Access Management

All privileged accounts (domain admins, root, database administrators, cloud IAM admins) must be managed through the Privileged Access Management (PAM) platform. Just-in-time access provisioning is mandatory - standing privileged access is prohibited. All privileged sessions must be recorded.

5. Network Security Controls

5.1 IoT and Non-Standard Device Security

Internet of Things devices, operational technology systems, smart building systems, and any non-standard network-connected devices present elevated risk due to limited patching capabilities and non-standard operating systems:

CRITICAL REQUIREMENT: MIG-POL-002-IOT01

All IoT devices must be placed on a dedicated, isolated VLAN with no routing to corporate data networks. IoT devices are **prohibited from initiating outbound connections to the public internet**. Any IoT device detected communicating with external IP addresses **must be automatically blocked** by network controls and an alert generated to the SOC within 5 minutes. **Monitoring-only mode is not acceptable** for IoT external communication controls; active blocking is required. Firmware updates must be delivered through an internal update proxy, not via direct internet download.

5.2 Environment Segmentation

Production, staging, development, and sandbox environments must be fully network-segmented. VPC peering, transit gateway attachments, or any network construct creating a direct path between production and non-production environments is prohibited. Data movement between environments must occur through approved CI/CD pipelines with PII masking applied.

5.3 Malware and Ransomware Protection

All endpoints and network gateways must implement layered malware defenses including signature-based detection, behavioral analysis, and cloud sandboxing:

POLICY MANDATE: MIG-POL-002-MAL01

All file downloads must be scanned by the cloud security gateway's malware protection engine. Unknown executables must be submitted to the cloud sandbox for behavioral analysis before delivery to the endpoint. Ransomware behavioral detection must be enabled on all endpoints and network segments, with automatic quarantine of affected hosts upon detection of mass file encryption or SMB encryption patterns.

5.4 DNS Security

POLICY MANDATE: MIG-POL-002-DNS01

All DNS queries from corporate networks must be resolved through Meridian Insurance Group's approved DNS infrastructure with DNS-layer threat protection enabled. DNS queries to known malicious domains (malware command-and-control, phishing infrastructure, botnet resolution) must be blocked automatically. Newly registered domains (less than 30 days old) must be blocked by default. DNS tunneling detection must be enabled with automatic blocking when high-entropy domain patterns are detected (entropy score above 85).

5.5 API and Application Security

POLICY MANDATE: MIG-POL-002-API01

All internet-facing API endpoints must be protected against common attack vectors including SQL injection, cross-site scripting (XSS), and volumetric abuse. Rate limiting must be enforced on all public API endpoints with a default threshold of 2,000 requests per IP per 5-minute window. API threat protection must be implemented at the cloud security gateway and/or WAF layer.

6. Security Monitoring and Incident Response

All security events from network devices, cloud services, endpoint agents, and application logs must be forwarded to the SIEM platform within 60 seconds of generation. The SOC operates 24/7/365 with a 15-minute SLA for initial triage of critical alerts. Security incidents must be reported within 30 minutes of detection and escalated to the CISO within 60 minutes if classified as Severity 1.

7. Compliance Auditing

Internal security audits are conducted quarterly. External penetration testing is conducted annually by an approved third-party firm. PCI DSS compliance assessments are conducted annually by a Qualified Security Assessor (QSA). All audit findings rated High or Critical must be remediated within 30 days. Medium findings within 90 days.

Appendix A: Definitions and Acronyms

Term	Definition
AES	Advanced Encryption Standard - symmetric block cipher
CASB	Cloud Access Security Broker
CISO	Chief Information Security Officer
DLP	Data Loss Prevention - technology to detect/prevent data exfiltration
IoT	Internet of Things - non-standard network-connected devices
MFA	Multi-Factor Authentication
NAIC	National Association of Insurance Commissioners
OFAC	Office of Foreign Assets Control
PCI DSS	Payment Card Industry Data Security Standard
PII	Personally Identifiable Information
SFTP	Secure File Transfer Protocol
SOC 2	Service Organization Control Type 2 audit
SSL/TLS	Secure Sockets Layer / Transport Layer Security
WAF	Web Application Firewall
ZPA	Zscaler Private Access
ZIA	Zscaler Internet Access
ZTNA	Zero Trust Network Access

Appendix B: Disclaimer

This document is the sole property of Meridian Insurance Group and contains confidential and proprietary information. It is intended exclusively for authorized personnel and must not be reproduced, distributed, or disclosed to third parties without prior written consent from the Chief Information Security Officer. This policy document is reviewed and updated according to the schedule defined in the Document Control section. Interim updates may be issued to address emerging threats, regulatory changes, or operational requirements. All employees and contractors are responsible for understanding and complying with this policy. Questions regarding interpretation or applicability should be directed to the Information Security Governance team.

Non-compliance with this policy may result in disciplinary action, up to and including termination of employment or contract, and may also result in civil or criminal penalties under applicable laws and regulations.